

Risks & Mitigation Strategies:

→ Risk 1: *Hardcoded Secrets in Code Repositories*

Explanation: Developers might accidentally commit API keys, passwords, or private keys into version control systems like GitHub.

Impact: Leaks can lead to data breaches, service abuse, or unauthorized access.

✅ Mitigation Strategy:

- Use secrets management tools like AWS Secrets Manager, HashiCorp Vault, etc.
- Integrate secret scanning tools (e.g., GitGuardian, truffleHog) into CI/CD pipelines.
- Enforce policies using pre-commit hooks.

Compliance with ISO 27001: A.9.2.3 - Management of privileged access rights.

→ Risk 2: *Insecure CI/CD Pipeline Configuration*

Explanation: Poorly configured pipelines might allow unverified code to reach production or run with excessive privileges.

✅ Mitigation Strategy:

- Use role-based access control (RBAC) and least privilege for CI/CD tools (like GitHub Actions, Jenkins).
- Enable build provenance and code signing.
- Use isolated environments for building and deploying.

Compliance with ISO 27001: A.12.1.2 - Change management.

→ Risk 3: *Unpatched or Vulnerable Containers*

Explanation: Using outdated or vulnerable images can expose your application to attacks like remote code execution or privilege escalation.

✅ Mitigation Strategy:

- Use trusted base images from official registries.
- Integrate container vulnerability scanners (e.g., Trivy, Clair) into CI/CD.
- Enable automated patching and container image signing.

Compliance with ISO 27001: A.12.6.1 - Management of technical vulnerabilities.

Security Best Practices in Cloud Deployments:

1. *Use Identity and Access Management (IAM):*
 - a. Grant least privilege.
 - b. Rotate credentials.
 - c. Use multi-factor authentication (MFA).
2. *Encrypt Data at Rest and in Transit:*
 - a. Use TLS for network encryption.
 - b. Use KMS for managing encryption keys.
3. *Implement Network Security:*
 - a. Use firewalls, security groups, and network ACLs.
 - b. Adopt zero-trust architecture for internal services.
4. *Regularly Monitor and Audit Logs:*
 - a. Use SIEM tools (e.g., AWS CloudTrail, Azure Monitor, ELK stack).
 - b. Implement intrusion detection systems (IDS).
5. *Automated Compliance Checks:*
 - a. Use tools like AWS Config, Azure Policy, or Open Policy Agent (OPA).
 - b. Automate alerts and remediation for policy violations.
6. *Secure APIs and Interfaces:*
 - a. Use authentication tokens (OAuth, JWT).
 - b. Rate limit and validate all API inputs.